

Information Security Policy

Organization: otterfund (unincorporated; operating name) **Product:** otterfund (<https://otterfund.ai>) **Policy owner:** Ibrahim Al-Tawil (Software Engineer) **Effective date:** July 21, 2026 **Version:** 1.0 **Review cadence:** Reviewed at least annually and after any material change to systems, vendors, or applicable law. **Next review due:** July 21, 2027.

✓ **Appendix A — Operational Confirmations completed and verified as of July 21, 2026.** The controls attested in this policy are in place. This policy and its confirmations are reviewed at least annually or upon material change.

1. Purpose

This policy defines how otterfund identifies, mitigates, and monitors information-security risks relevant to its business: a consumer personal-finance application that connects to users' bank and financial accounts (via Plaid) and stores their financial data. It establishes the security controls, responsibilities, and review processes that protect the confidentiality, integrity, and availability of that data.

This policy is operationalized through the specific technical controls described below (encryption, access management, vulnerability management, logging), the automated enforcement in the codebase and CI/CD pipeline, and the governance/review process in Section 12.

2. Scope

This policy applies to:

- All personnel (founders, employees, contractors) with access to otterfund systems or data.
- All production assets: the application (hosted on Vercel), the primary database (Supabase, managed Postgres), and all third-party services that process consumer data (see Section 9).
- All consumer data received from Plaid and other sources (account balances, transactions, investment holdings, account metadata) and all user profile/credential data.
- All company-controlled endpoints (laptops/workstations) used to access production systems or source code.

3. Roles and Responsibilities

- **Policy Owner (Ibrahim Al-Tawil, Software Engineer)** — owns this policy, approves exceptions, ensures annual review, and is the point of contact for security matters and incident response.
- **All personnel** — responsible for following this policy, using MFA, protecting credentials, using only approved systems for company data, and reporting suspected security incidents immediately to the

Policy Owner.

- **Contractors** — bound to equivalent obligations via contract before receiving any access; access is time-limited and revoked at engagement end.

4. Risk Management (Identify · Mitigate · Monitor)

otterfund operates a continuous, lightweight risk-management process appropriate to its size:

- **Identify.** At least annually, and whenever a significant change is introduced (new subprocessor, new data type, major feature), the Policy Owner reviews the data flows and threat surface — authentication, bank-data ingestion (Plaid), data storage, third-party processors, and application code — to identify information-security risks. Automated tooling (dependency scanning, CI checks) continuously surfaces technical risks.
- **Mitigate.** Identified risks are addressed through the controls in Sections 5–11 (encryption, least-privilege access, MFA, secure development, vulnerability remediation, vendor due diligence). Each material risk is assigned an owner and a remediation timeline.
- **Monitor.** Risks and controls are monitored on an ongoing basis via automated dependency/security alerts (Dependabot), CI gate results, application security-event logging (Section 8), and host/provider audit logs. Open risks are tracked to closure.

5. Data Protection and Encryption

- **Data classification.** Consumer financial data (balances, transactions, holdings, account metadata) and authentication credentials are treated as **Sensitive/Confidential** and receive the highest level of protection.
- **Encryption in transit.** All traffic between clients and servers, and between servers and subprocessors, is encrypted using **TLS 1.2 or higher** (TLS 1.3 where supported). HTTP Strict Transport Security (HSTS) is enforced on the application.
- **Encryption at rest.** Consumer data received from the Plaid API and all other application data are encrypted at rest:
- The **primary database (Supabase, managed Postgres)** encrypts all data at rest using **AES-256**.
- **Plaid access tokens** receive an additional layer of **application-level AES-256-GCM encryption** before being written to the database; they are never stored or transmitted in plaintext and never exposed to the client.
- **Secrets management.** Application secrets (API keys, database credentials, the token-encryption key, webhook/cron secrets) are stored in the hosting provider's encrypted environment-variable store and are never committed to source control.
- **Credential handling.** otterfund never sees or stores users' bank login credentials — these are handled entirely by Plaid. User account passwords are handled by the authentication provider (Supabase) and are never stored in plaintext by otterfund.

6. Identity and Access Management

- **Least privilege.** Access to production assets and consoles (Vercel, Supabase, GitHub, Stripe, Anthropic, and other subprocessors) is granted on a least-privilege, need-to-know basis.
- **Unique accounts.** Every individual uses their own named account; shared/generic logins are prohibited.
- **Multi-factor authentication (MFA).** MFA is required for all administrative access to systems that store or process consumer financial data (Vercel, Supabase, GitHub, Stripe, Anthropic). See Appendix A.
- **Application access control.** In the application, all data access is authorization-scoped to the authenticated user. Server-side authorization guards run on every request path (proxy-level auth/redirect enforcement plus per-request user resolution), and every data query and mutation is scoped to the owning user so one user can never read or modify another's data. Access to bank-connection actions is additionally rate-limited and quota-enforced per user.
- **Non-human authentication.** Service-to-service and machine authentication uses API tokens/keys transmitted over TLS; inbound webhooks are cryptographically verified (Plaid via ES256 JWT signature, Stripe via signed-payload verification). Secrets are stored in the hosting provider's encrypted environment store, never in source control.
- **Periodic access reviews.** Access to production consoles and sensitive data is reviewed on a periodic basis (at least quarterly) to confirm each person's access remains appropriate and to remove any access that is no longer needed.
- **Session and auth security.** Authentication is provided by Supabase (email/password and Google OAuth). Bot/abuse protection (CAPTCHA) is applied to authentication flows.
- **Offboarding.** When personnel or contractors depart, their access to all production systems, source control, and subprocessor consoles is revoked promptly.

7. Infrastructure and Network Security

- The application runs on managed, reputable cloud infrastructure (Vercel for compute, Supabase for the database), which provides physical security, network isolation, and platform patching for the underlying infrastructure.
- The database is not publicly exposed for application data access; all application data access is mediated through the server-side data layer (Prisma/GraphQL). Authentication clients are used only for auth, never for direct data access.
- Inbound webhooks (Plaid, Stripe) are cryptographically verified before processing: Plaid webhooks are validated via ES256 JWT signature verification against Plaid's published keys plus a body-hash integrity check; scheduled sync jobs are authenticated with a shared secret. Webhook and link endpoints are rate-limited to prevent abuse.

8. Logging and Monitoring

- The application emits **security-event logs** (via a dedicated logging module) for security-relevant actions, including account deletion and other sensitive operations.
- Error handling for third-party (Plaid) calls is designed to **never log secrets** — only safe scalar fields (status, error code/type, request id, message) are recorded, preventing accidental exposure of access tokens or API secrets in logs.
- Platform-level audit logs from the hosting and database providers (Vercel, Supabase) are available for access and infrastructure monitoring.

9. Third-Party / Subprocessor Management

otterfund uses the following subprocessors to deliver the service. Each is a reputable provider with its own security program; data shared is limited to what each function requires:

Subprocessor	Purpose	Data processed
Supabase	Authentication + primary database hosting	Credentials, profile, all app data
Plaid	Bank/financial-account connections	Bank login (handled by Plaid, not stored by us), balances, transactions
Anthropic (Claude)	AI advisor, statement parsing, categorization	Financial data, transactions, uploaded statements, chat messages
Stripe	Payment/subscription processing	Billing details, payment-card data (card numbers not stored by us)
Twelve Data	Market quotes / security search	Ticker symbols, security names (no personal data)
Google (favicon service)	Merchant/brand logos	Merchant domains (no personal data)

New subprocessors are reviewed for security and privacy posture before adoption. The public list of subprocessors is maintained in the Privacy Policy.

10. Secure Development and Vulnerability Management

- **Secure SDLC.** All changes are made in version control (GitHub) and pass an automated CI pipeline before merge to the production branch. The pipeline enforces linting, TypeScript type-checking, a production build, and Prisma schema validation.
- **Dependency / software-composition scanning.** Automated dependency scanning (GitHub Dependabot) runs weekly across application and CI dependencies; **security advisories are delivered immediately** rather than on the weekly cadence.

- **Dependency audit gate.** CI runs `npm audit` on production dependencies and **fails the build on CRITICAL advisories**; HIGH advisories are triaged and remediated via Dependabot pull requests.
- **Remediation SLA.** Identified vulnerabilities are remediated within defined timeframes based on severity: **Critical within 7 days, High within 30 days, Medium within 90 days** (Low: best-effort). CRITICAL advisories additionally block the CI build, so they cannot reach production unresolved. Security-relevant dependency updates are reviewed and merged promptly; underlying platform/OS patching is handled by the managed hosting providers (Vercel, Supabase).
- **End-of-life (EOL) software.** Use of end-of-life or unsupported components is actively monitored and addressed: dependencies are kept current via Dependabot, and the application runs on actively-supported runtimes (current Node.js), with the managed platforms (Vercel, Supabase) maintaining the underlying runtime/OS lifecycle.
- **Endpoint / production-host vulnerability management.** See Appendix A for the endpoint (laptop/workstation) controls in effect.

11. Incident Response

- Any suspected or confirmed security incident (unauthorized access, data exposure, credential compromise, subprocessor breach) must be reported to the Policy Owner immediately.
- The Policy Owner leads response: **contain** (revoke access, rotate secrets, disable affected components), **assess** (scope and data affected), **remediate**, and **notify** affected users and Plaid/regulators as required by applicable law and contractual obligations, within the required timeframes.
- Secrets (API keys, the token-encryption key, database credentials) can be rotated via the hosting provider's environment store, and Plaid connections can be revoked per user (see the Data Retention & Disposal Policy).
- Post-incident, a brief review captures root cause and corrective actions.

12. Business Continuity and Backups

- otterfund currently runs on the **free tiers** of Supabase (database/authentication) and Vercel (hosting). The Supabase free tier does **not** include automated database backups; a move to paid plans that provide automated, encrypted backups (and point-in-time recovery) is planned, at which point restoration procedures will rely on the provider's backup capabilities. Until then, the absence of database backups is a known and accepted risk appropriate to the current early stage, and it means user data deleted per the Data Retention & Disposal Policy is permanently erased with no backup copy.
- Infrastructure is managed and hosted by the cloud providers (Vercel, Supabase), which handle platform availability and redundancy for their respective tiers.

13. Data Retention, Disposal, and Privacy

- Data retention and disposal are governed by otterfund's **Data Retention & Disposal Policy** (companion document), which defines retention periods, the deletion/erasure mechanism, backup purging, and user rights (data export and permanent deletion).
- **Consent and privacy.** Users must accept the Terms of Service and Privacy Policy (a mandatory, gated acceptance) before an account is created. The Privacy Policy describes what is collected, the legal bases (including consent), user rights, and subprocessors. otterfund's practices are designed to comply with applicable privacy laws, including PIPEDA (Canada) and, where applicable, GDPR and CCPA/CPRA.

14. Personnel Security

- Personnel and contractors receive access only after agreeing to confidentiality and security obligations.
- Endpoints used to access production systems or source code are secured with the following controls, currently in place: **full-disk encryption (FileVault)**, **automatic installation of OS security updates**, and a **password-protected screen lock**. Personnel use MFA (Section 6) and a password manager for unique credentials.

15. Policy Governance

- This policy is reviewed at least annually and upon material change, updated as needed, and re-approved by the Policy Owner.
- Exceptions require documented approval from the Policy Owner with a defined scope and expiry.
- Violations may result in access revocation and, for personnel/contractors, disciplinary or contractual action.

Appendix A — Operational Confirmations

Complete/confirm these before relying on this policy in an attestation. Each maps to a control asserted above.

- ☒ **Company name:** otterfund (unincorporated operating name). Not registered, so no registered address applies.
- ☒ **Policy Owner named:** Ibrahim Al-Tawil (Software Engineer).
- ☒ **Enable MFA** on every console that touches consumer data: **Vercel, Supabase, GitHub, Stripe, Anthropic** (Sections 6, 10). *MFA enforced on all administrative consoles as of July 21, 2026.*
- ☒ **Endpoint controls confirmed** on the machine used for production/source access (as of July 21, 2026): FileVault full-disk encryption **on**, automatic OS security updates **on**, password-protected screen lock **on**. Anti-malware/EDR not deployed (optional at current scale).

- ☑ **Offboarding process documented** (Section 6): on any personnel/contractor departure, access to Vercel, Supabase, GitHub, Stripe, and Anthropic is revoked promptly. otterfund is currently a solo operation, so no third-party access is presently outstanding.
- ☑ **Next annual review date set:** July 21, 2027 (see header). Add a calendar reminder to perform the review.